



File No.: EXP202213029

SANCTIONING PROCEDURE RESOLUTION

From the procedure instructed by the Spanish Agency for Data Protection and based on the following:
BACKGROUND

FIRST: Mr. A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on October 27, 2022. The complaint is directed against DIGI SPAIN TELECOM, S.L. with NIF B84919760 (hereinafter, DIGI). The reasons for the complaint are as follows:

The complainant states that without his consent, DIGI provided and activated a second SIM card, without presenting the original ID and failing to comply with all necessary protocols for the delivery of these cards.

That at 10:30 a.m. on October 26, 2022, his mobile phone ***PHONE.1 lost service, after which he received an email from DIGI explaining that a second SIM card had been activated with his number. He contacted the operator to inform them that he had not authorized this, and after this, attempts were made to access his bank accounts, prompting him to instruct his bank to cancel all his cards and change his passwords.

Subsequently, DIGI provided him with a second SIM which was activated at 1:50 p.m. on the indicated day, and another security filter was established with a password provided by the complainant, which had to be supplied for any transaction.

On the same day at 4:20 p.m., he lost service again and received another email informing him that another SIM had been activated with his number by a supposed impersonator.

He adds that he contacted DIGI again, and they provided him with another SIM which he collected at a physical store in his locality, just like the first one, where he had to identify himself with his original ID. However, at no time was he asked for the filter that had been established to provide the password to authorize and facilitate the SIM card.

Along with his complaint, he submits the emails sent to the defendant dated October 26 and 27, 2022, and DIGI's response dated the 27th of the same month and year.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to DIGI for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on December 19, 2022, as recorded in the acknowledgment of receipt in the file.

DIGI requested an extension of the deadline to respond to this Agency on January 19, 2023.

On February 2, 2023, a response was received by this Agency indicating: "That a first duplicate of the SIM card associated with the mobile line ***PHONE.1: As recorded in DIGI's systems, on October 25, 2022, at 7:39 p.m., a request for a duplicate SIM for the mobile line ***PHONE.1 was received at the DIGI stand located in the shopping center ***ESTABLISHMENT.1 (***ADDRESS.1). For the processing of this request, the applicant and presumed holder of the line identified himself as the complainant, using an original identity document, a copy of which was obtained at that time.

The aforementioned request for a duplicate, along with the accompanying documentation, was sent to DIGI's BackOffice team, in accordance with the procedure currently in force at DIGI, which requires not only obtaining a copy of the applicant's identity document but also reviewing the request and documentation by that team.

Thus, given that presumably the request and the associated documentation were correct, the request

was validated by DIGI's BackOffice team, and the activation of the duplicate SIM was carried out the following day at 10:11 a.m.

At the moment the duplicate was activated, an informative SMS was sent to the phone number ***PHONE.1 informing of the successful activation of the requested duplicate.

A second duplicate of the SIM card associated with the mobile line ***PHONE.1: On October 26, 2022, at 12:07 p.m., a person identified as the complainant contacted DIGI by phone to inform that he had received an SMS on his mobile line indicating that a duplicate SIM had been carried out for that same number.

In light of this information, after passing the corresponding security challenge to identify the caller as the holder of the line, and confirming with him the next steps, DIGI proceeded to block the line as a security measure until the holder confirmed having made a new duplicate. An internal ticket was also opened for a possible case of identity theft, and the caller, the complainant, was requested to file a report with the Police and then send DIGI the corresponding complaint along with a copy of his identity document to continue with the appropriate analysis.

On October 26, 2022, at 1:06 p.m., a request for a second SIM duplicate for the line ***PHONE.1 was received. This new duplicate was requested at the establishment of our distributor B.B.B.

(***ADDRESS.2). For the processing of this request, the applicant and presumed holder of the line identified himself as the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/21

Claimant, through their original identity document, a copy of which was obtained at that time.

This new request for a duplicate, along with the accompanying documentation, was sent again to the BackOffice team of DIGI for validation according to the procedure established by DIGI. After the corresponding review of the request and its documentation, and being aware of the previous claim call from the line holder warning of an impersonation, and of the internal ticket opened, the activation of the new SIM duplicate was carried out at 13:58 hours on that same day, October 26, 2022.

At the moment the duplicate was found to be active, an informative SMS was sent again informing of the successful activation of the requested duplicate. On the same day, October 26, 2022, at 15:23, a new call was received from the line ***PHONE.2 from a person who again identified themselves as the claimant, asking about their line. They were asked about the report of usurpation, to which the interlocutor indicated that they had not filed any report, became nervous, and hung up.

From the DIGI Claims team, after analyzing the facts and following the aforementioned call, a note was made in red on the ID of the line in question with the following wording: Claims//A fraudulent SIM duplicate has been used for this customer, we have added the real ID to the ID//Please check ID before validating duplicate//Thank you//We verify that the possible usurper is calling from line ***PHONE.2, if someone calls from this line, do not provide any data or information. Additionally, at 15:41, DIGI called the customer holder of the line (calling the line ***PHONE.1 that was the subject of the alleged fraud), and the holder informed that they would send a copy of the report and their identity document.

It was also agreed with the customer to establish a security keyword, which was also noted in red and associated with the ID.

A third duplicate of the SIM card associated with the mobile line ***PHONE.1: On the same day, October 26, 2022, at 16:19 hours, a third request for a duplicate was received for the mobile line ***PHONE.1. This third duplicate was requested at our distributor's establishment C.C.C.

(***ADDRESS.3).

For the processing of this request, the applicant again identified themselves as the claimant, through an original identity document, a copy of which was obtained at that time. The new request for a duplicate, along with the accompanying documentation, was again sent to the BackOffice team of DIGI for validation.

However, in this validation, the advisor assigned to the task did not follow the procedure that DIGI has

established internally (and regarding which all its BackOffice advisors are informed and trained) for the validation of SIM duplicates according to the currently applicable procedure at DIGI.

It is worth mentioning that this procedure, as it cannot be otherwise, involves, among other things, the obligation of the DIGI advisor to (1) review all the

4/21

documentation associated with the ID of the line for which a duplicate is being requested, including the tickets and observations that appear in said ID; (2) check if there are any previous duplicate requests that may indicate that the holder could be a victim of some type of identity fraud; and (3) contact the customer to confirm the keyword they set as a security measure to prevent unauthorized duplicates. Unfortunately, in this case, due to negligence, the advisor assigned to this validation did not carry out any of these checks, failing to fulfill their job responsibilities, and proceeded to validate the new duplicate request, which was activated at 16:30 hours on October 26, 2022, with the corresponding informational SMS sent.

A fourth duplicate of the SIM card associated with the mobile line ***PHONE.1: On the same day, October 26, 2022, at 17:44 hours, a call was again received from a person, presumably the claimant, to report that they had again suffered a fraudulent duplicate of the SIM card associated with their line. After passing the corresponding telephone identification challenge and confirming the next steps with them, DIGI proceeded to block the line as a security measure until the holder confirmed having made a new duplicate. They were also urged to file the corresponding complaint and send it to DIGI along with a copy of their identity document. After the previous call, at 19:21 hours, a fourth SIM duplicate request was made at our distributor B.B.B. (**ADDRESS.2), which was activated, once the request was validated, at 19:47 hours, with an SMS sent informing of the activation.

For the processing of this request, the applicant and presumed holder of the line identified themselves as the claimant, using their original identity document, a copy of which was obtained at that time. The advisor who, failing to comply with their obligations and the established procedure for the validation of duplicates, validated the third duplicate without checking the warnings and documentation already associated with the claimant's ID, was reprimanded.

Additionally, they were included in a training reinforcement plan for the proper control of DIGI's procedures, especially regarding the validation of duplicates.

In the case of the second allegedly fraudulent duplicate (the third duplicate in the sequence of events described in section 1 of this document), it was only possible because the usurper took advantage of the negligence of the DIGI advisor who validated said duplicate, who should have fulfilled, and did not fulfill, their obligations, and should have followed, and did not do so, the procedure that DIGI has implemented for the validation of duplicates.”

THIRD: In accordance with Article 65 of the LOPDGDD, when a complaint is presented to the Spanish Agency for Data Protection (hereinafter, AEPD), it must evaluate its admissibility for processing, notifying the complaining party of the decision on admission or inadmission for processing within three months from the date the complaint was received by this Agency. If, after three months,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/21

If such notification does not occur within this period, it shall be understood that the processing of the claim continues in accordance with the provisions of Title VIII of the Law. This provision also applies to the procedures that the AEPD must process in exercising the powers conferred upon it by other laws. In this case, taking into account the aforementioned and that the claim was submitted to this Agency on October 27, 2022, it is communicated that your claim has been admitted for processing, dated January 27, 2023, after three months have passed since it was received by the AEPD.

FOURTH: According to the report obtained from the AXESOR tool, the entity DIGI SPAIN TELECOM, S.L. is a large company established in 2006, with a turnover of 364,201,000 euros in 2021.

FIFTH: On March 27, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate

sanctioning proceedings against the respondent, in accordance with the provisions of Articles 63 and 64 of the LPACAP, for the alleged infringement of Article 6.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), classified under Article 83.5 of the GDPR.

SIXTH: On April 10, 2023, DIGI requested an extension of the legal deadline granted to respond to said request and a copy of the file.

SEVENTH: On April 26, 2023, a letter from the representative of DIGI was received by this Agency, in due time and form, in which, in summary, it is stated that they reiterate the allegations previously presented, first indicating chronologically how the events occurred, specifying the security protocol and the measures adopted regarding these events, stating that the identity theft and the illegitimate access to the data of the holder occurred prior to any contact with DIGI and is the cause that led to the incident and the issuance of the duplicate SIM card.

Consequently, they state that it is not possible to associate DIGI with the performance of unauthorized processing of personal data, given that its actions are limited to complying with its processes and obligations.

That is to say, during the process of requesting and delivering the duplicate, there is processing of the personal data provided to DIGI in order for it to verify the identity of the interlocutor, first by telephone means and subsequently in person.

Furthermore, it is stated that only a particular action by an employee, violating the instructions they had and therefore their work obligations, without DIGI having the capacity to prevent it, allows for the bypassing of this protocol.

On the other hand, it is pointed out that the AEPD unequivocally imposes on DIGI an objective liability, in which, regardless of the diligence and measures deployed, the culpability of the entity is declared.

The AEPD seems to confuse the concept of proactive responsibility with the obligation of result imposed by objective liability. In the present case, the existence of a...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/21

strict control, prior and subsequent to the request for the duplicate, the establishment of prior and subsequent measures, as well as the existence of measures aimed at preventing these practices beforehand.

This is why the responding party considers that the present Initiation Agreement is not in accordance with the law, as it imposes on DIGI an obligation of result, based solely on the harmful outcome produced by the fraudulent activity of a third party, without taking into account the diligence used and without considering the deployment of technically adequate measures that have been implemented.

On the other hand, it expresses the lack of proportionality indicating that the AEPD opened sanctioning procedures, during the year 2021, against the four major telecommunications operators in the national landscape, after conducting a general review of their procedures for duplicating SIM cards and the subsequent SIM SWAPPING procedures. This generic review resulted in a sanction for each of the telecom operators, and in the case of DIGI, up to eleven sanctioning procedures.

Specifically, they mention the sanction imposed in the sanctioning procedure of the AEPD

PS/000027/2021, which they consider to be analogous and pertains to identical factual assumptions.

Furthermore, it points out that the following mitigating circumstances exist in the present case that have not been considered in the appropriate graduation of the sanction:

The absence of prior infringements committed by DIGI (art. 83.2 e) GDPR).

At no time have special categories of data been dealt with (Art. 83.2 g) GDPR).

The degree of cooperation of DIGI with the AEPD in order to remedy a supposed infringement and mitigate its possible adverse effects (art. 83.2 f) GDPR).

The nonexistent benefit obtained (Art. 83.2 k).

It requests that a resolution be issued indicating the filing of the procedure.

Subsidiarily, a warning and, as a last resort, that the proposal contained in the Initiation Agreement be moderated or adjusted.

EIGHTH: On April 27, 2023, the instructor of the procedure agreed to carry out the following evidence: <<1. The complaint filed by Mr. A.A.A. and its documentation, the documents obtained and generated during the admission phase of the complaint, are reproduced for evidentiary purposes. 2. Likewise, the allegations to the initiation agreement of the referenced sanctioning procedure, submitted by DIGI SPAIN TELECOM, S.L., and the accompanying documentation are reproduced for evidentiary purposes>>.

NINTH: On May 31, 2023, a resolution proposal was formulated, proposing that the Director of the Spanish Agency for Data Protection sanction DIGI SPAIN TELECOM, S.L., with NIF B84919760, for an infringement of Article 6.1 of the GDPR, classified under Article 83.5 a) of the GDPR, with the corresponding sanction being a fine in the amount of 70,000 euros (seventy thousand euros).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/21

TENTH: Following the notification of the proposed resolution, a written statement of allegations was submitted on June 19, 2023, in which, in summary, it is argued that the allegations previously presented are reiterated, and that the report issued by the European Union Agency for Cybersecurity confirms that, to carry out a fraudulent duplication of a SIM card, the scammer needs to have access to some of the personal data of the victim, a customer of the operator. That is to say, cybercriminals have personal data of their victims prior to approaching the Mobile Network Operator.

It is pointed out that this is what occurred in the present case; the victim lost control over their personal data in favor of the impersonator before the latter contacted DIGI. "That is to say, it is through the phishing attack where the victims, in this case, the Claimant and their spouse, lose control over their personal data, and it is this fact that triggers and enables the commission of the fraud."

For this reason, the responding party considers that the Proposal is not legally justified, as it imposes on DIGI an obligation of result, consisting of the establishment of infallible measures regarding risks that are imposed on it by third parties who, unilaterally, have decided to outsource, without DIGI's consent, their own security obligations as data controllers. It goes so far as to attribute a violation of Article 6.1 of the GDPR based solely on the harmful result produced by the fraudulent intervention of a third party that surpasses security measures, without considering the diligence used, and without taking into account the deployment of technically adequate measures implemented regarding a processing for which DIGI neither decides the purpose nor the means.

Regarding the lack of proportionality of the proposed sanction and that, following the appropriate procedures, a resolution should be issued indicating the filing of procedure EXP202213029.

From the actions taken in the present procedure and the documentation in the file, the following has been established:

PROVEN FACTS

1st. The claimant filed a complaint with this Agency on October 27, 2022, stating that at 10:30 AM on October 26, 2022, their mobile phone ***PHONE.1 lost service, after which they received an email from DIGI explaining that a second SIM card had been activated with their number.

2nd. DIGI stated that, on October 25, 2022, a third party identifying themselves as the claimant requested a duplicate SIM card for the mobile line ***PHONE.1, through the DIGI stand located in a shopping center, displaying the ID with the claimant's number, and the DIGI distributor proceeded to manage the request for the duplicate card.

Subsequently, when the claimant contacted DIGI, they first suspended the line and later, on October 26, 2022, they recovered it.

3rd. DIGI stated that, on October 26, 2022, the DIGI telephone customer service received a new call from a third party identifying themselves as the claimant, and when trying to confirm their identity, the call ended. DIGI recorded this incident and contacted the claimant to establish a security password to

request a duplicate SIM card.

4th. DIGI stated that, on October 26, it received another request for a duplicate SIM card at a different establishment from the first, for the line ***PHONE.1. There, they proceeded to issue the SIM card to that third party who was not the account holder.

5th. The line was activated irregularly from 4:30 PM to 5:44 PM on the same day, at which point the DIGI agent proceeded to suspend the service.

6th. The claimant contacted DIGI again, and they provided another SIM which the claimant collected at a physical store in their locality, just like the first one, where they had to identify themselves with their original ID, but at no time were they asked for the filter that was established to provide the key to authorize and facilitate the SIM card.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued in its development, and, in so far as they do not contradict them, by the general rules on administrative procedures."

II

Obligation Breached

The responding party is accused of committing an infringement for violation of Article 6 of the GDPR, "Lawfulness of processing," which states in its paragraph 1 the circumstances under which the processing of third-party data is considered lawful:

"1. Processing shall be lawful only if at least one of the following conditions is met:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/21

a) The data subject has given their consent for the processing of their personal data for one or more specific purposes;

b) The processing is necessary for the performance of a contract in which the data subject is a party or for the application at their request of pre-contractual measures;

c) The processing is necessary for compliance with a legal obligation to which the data controller is subject;

d) The processing is necessary to protect vital interests of the data subject or of another natural person;

e) The processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller;

f) The processing is necessary for the purposes of legitimate interests pursued by the data controller or by a third party, provided that such interests do not override the interests or the fundamental rights and freedoms of the data subject which require protection of personal data, particularly when the data subject is a child. The provisions of item f) of the first paragraph shall not apply to processing carried out by public authorities in the exercise of their functions.

In response to the allegations presented by DIGI, the following should be noted:

Regarding the fact that identity theft and access to the data of the data subject in an illegitimate manner occurs prior to any contact with DIGI and is the cause that triggers the incident and the issuance of the duplicate SIM card. Consequently, it is not possible to associate DIGI with the

performance of unauthorized processing of personal data, given that its actions are limited to complying with its processes and obligations.

Indeed, the issuance of a duplicate is not sufficient to carry out banking operations in the name of the data subjects; certainly, to complete the fraud, it is necessary for a third party to "impersonate" the identity of the data subject before the financial entity.

This, in principle, leads to processing outside the principle of lawfulness since a third party is processing data, as they have access to it, without any legal basis, in addition to the violation of other principles such as confidentiality.

For this reason, this is a process where the diligence provided by the operators is fundamental to prevent this type of fraud and violations of the GDPR. Diligence that translates into the establishment of adequate measures to ensure that data processing is in accordance with the GDPR.

Identical considerations apply to the actions of banking entities that provide payment services, in which this type of fraud begins, as the third party has access to the credentials of the affected user and poses as them.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/21

Insofar as these entities are responsible for the processing of their clients' data, they bear the same obligations as those indicated so far for the operators regarding compliance with the GDPR and the LOPDGDD, as well as those arising from Royal Decree-Law 19/2018, of November 23, on payment services and other urgent measures in financial matters.

Well, DIGI has provided a duplicate of the SIM card to a third party other than the legitimate holder of the mobile line, after third parties bypassed the existing security policy, which evidences a breach of the duty to protect customer information.

Denying the occurrence of negligent conduct on the part of DIGI would be equivalent to acknowledging that its behavior—by action or omission—has been diligent. Obviously, we do not share this perspective of the facts, as the lack of due diligence has been established. The Administrative Court ruling of October 17, 2007 (rec. 63/2006) is very illustrative; starting from the premise that these are entities whose activities involve continuous processing of customer data, it indicates that "...the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

It is established in the file that adequate security has not been guaranteed in the processing of personal data, given the result produced by the identity theft. That is to say, a third party has managed to access the personal data of the holder of the line.

Regarding DIGI's responsibility, it should be indicated that, in general, DIGI processes its clients' data under the provisions of Article 6.1 b) of the GDPR, as it is considered necessary processing for the execution of a contract in which the data subject is a party or for the application at the request of the data subject of pre-contractual measures. In other cases, it bases the lawfulness of the processing on the grounds provided in Article 6.1.a), c), e), and f) of the GDPR.

On the other hand, to complete the fraud, it is necessary for a third party to "impersonate the identity" of the data holder to receive the duplicate of the SIM card. This, in principle, leads to processing outside the principle of lawfulness since a third party is processing data, as they have access to it, without any legal basis, in addition to the violation of other principles such as confidentiality.

Certainly, the principle of responsibility provided in Article 28 of the LRJSP states that: "Only individuals and legal entities may be sanctioned for acts constituting administrative infractions, as well as, when a law recognizes them the capacity to act, the groups of affected parties, unions, and entities

without legal personality and independent or autonomous assets, that are found responsible for them by way of intent or negligence.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
11/21

However, the manner of attributing responsibility to legal entities does not correspond with the forms of culpability that are attributable to human conduct, whether intentional or negligent. Thus, in the case of violations committed by legal entities, although the element of culpability must be present, it is necessarily applied differently than it is with natural persons.

According to STC 246/1991, "(...) this distinct construction of the attribution of the authorship of the infringement to the legal entity arises from the very nature of the legal fiction to which these subjects respond. They lack the volitional element in the strict sense, but not the capacity to infringe the rules to which they are subject. The capacity to infringe and, therefore, the direct reproachability that derives from the legal good protected by the norm that is infringed and the necessity for that protection to be genuinely effective, along with the risk that, consequently, the legal entity must assume, which is subject to compliance with that norm" (in this sense, STS of November 24, 2011, Rec 258/2009). To the above, it should be added, following the judgment of January 23, 1998, partially transcribed in the SSTS of October 9, 2009, Rec 5285/2005, and October 23, 2010, Rec 1067/2006, that "although the culpability of the conduct must also be subject to proof, it must be considered in relation to the assumption of the corresponding burden, that ordinarily the volitional and cognitive elements necessary to appreciate it form part of the proven typical conduct, and that their exclusion requires evidence of the absence of such elements, or in its normative aspect, that due diligence has been exercised by the one who claims its non-existence; in short, the mere invocation of the absence of fault is not sufficient for exculpation against a typically unlawful behavior."

Consequently, the lack of culpability is dismissed. The ultimate responsibility for the processing remains attributed to the responsible party, who determines the existence of the processing and its purpose. Let us remember that, generally speaking, operators process their customers' data under the provisions of Article 6.1 b) of the GDPR, as it is considered necessary for the execution of a contract in which the data subject is a party (...). In this regard, DIGI has a network of sales representatives, points of sale, and authorized distributors through a distribution contract to offer DIGI's services. Among these services offered from its points of sale is the issuance of duplicates of SIM cards corresponding to a mobile phone line.

Regarding the breach of the principle of proportionality, the GDPR expressly provides for the possibility of gradation, through the provision of fines that can be modulated, taking into account a series of circumstances of each individual case.

As for the imposition of a warning, admonition, or the adoption of corrective measures in accordance with Article 58 of the GDPR, a deterrent fine is one that has a genuine deterrent effect. In this regard, the Judgment of the CJEU, of June 13, 2013, Versalis Spa/Commission, C-511/11, ECLI:EU:C:2013:386, states:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
12/21

“94. Regarding, firstly, the reference to the Showa Denko/Commission judgment, previously cited, it is necessary to point out that Versalis interprets it incorrectly. Indeed, the Court of Justice, when stating in paragraph 23 of that judgment that the deterrent factor is assessed taking into account a multitude of elements and not just the particular situation of the company in question, was referring to points 53 to 55 of the conclusions presented in that case by Advocate General Geelhoed, who essentially indicated that the deterrent multiplier coefficient can aim not only at a 'general deterrence', defined as an action to disincentivize all companies, in general, from committing the infringement in question, but also at a

'specific deterrence', consisting of deterring the specific defendant from infringing the rules again in the future. Therefore, the Court of Justice only confirmed, in that judgment, that the Commission was not obliged to limit its assessment to factors related solely to the particular situation of the company in question."

"102. According to established case law, the objective of the deterrent multiplier factor and the consideration, in this context, of the size and global resources of the company in question lies in the desired impact on the aforementioned company, as the sanction must not be insignificant, especially in relation to the financial capacity of the company (in this sense, see, in particular, the judgment of June 17, 2010, Lafarge/Commission, C-413/08 P, Rec. p. I-5361, paragraph 104, and the order of February 7, 2012, Total and Elf Aquitaine/Commission, C-421/11 P, paragraph 82)."

We must take into account the singular circumstance of the claim presented, through which it can be established that, from the moment the impersonating individual performs the substitution of the SIM, the victim's phone is left without service, transferring control of the line to the impersonators. Consequently, their powers of disposition and control over their personal data are affected, which constitute part of the content of the fundamental right to data protection as indicated by the Constitutional Court in Judgment 292/2000, of November 30, 2000 (FJ 7). Thus, by obtaining a duplicate of the SIM card, access to contacts or applications and services that have as a recovery procedure the sending of an SMS with a code to modify passwords is enabled under certain circumstances. Ultimately, they can impersonate the identity of the affected individuals, being able to access and control, for example: email accounts; bank accounts; applications such as WhatsApp; social networks, such as Facebook or Twitter, and a long etc. In summary, once the access key is modified by the impersonators, the victims lose control of their accounts, applications, and services, which poses a significant threat. Ultimately, it is the data controller who has the obligation to integrate the necessary guarantees in the processing, with the aim of, by virtue of the principle of proactive responsibility, complying with and being able to demonstrate compliance, while respecting the fundamental right to data protection.

DIGI cites in its defense a series of resolutions issued by the AEPD, stating that in contrast to the sanction imposed on DIGI, another telecommunications operator is imposed, for an infringement of Article 5.1(f) of the GDPR, classified as very serious for the purposes of prescription in Article 72.1(a) of the LOPDGGD, an administrative fine of 200,000 euros (two hundred thousand).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/21

euros).

On this particular matter, it is important to highlight that these procedures aimed to analyze the processes followed to manage SIM change requests by the telecommunications operator, identifying any vulnerabilities that may exist in the implemented operational procedures, to detect the causes for which these cases may be occurring, as well as to find points of non-compliance, improvement, or adjustment, in order to determine responsibilities, reduce risks, and enhance the security in the processing of personal data of the affected individuals.

The sanctioning procedure PS/000027/2021, processed against the other operator, was charged with the violation of Article 5.1(f); it is not charged with fraud, nor with the processing of data without legitimacy, but rather with a lack of guarantees regarding security measures that results in the transfer of data to a third party.

In the present sanctioning procedure, the sanction is imposed because DIGI provided a duplicate of the claimant's SIM card to a third party, without their consent and without verifying the identity of said third party, and for this reason, Article 6.1 of the GDPR is invoked.

Based on the aforementioned, in the analyzed case, the diligence employed by the defendant to identify the person who requested a duplicate of the SIM card is called into question.

In this case, it is established that two fraudulent duplicates were produced, dated October 25 and 26, 2022; the operator DIGI processed the issuance of two fraudulent duplicates of the SIM card of the line

***PHONE.1, belonging to the claimant.

The first of the fraudulent duplicates was carried out on October 25, 2022, at 19:39 hours, with the presentation of a national identity document that does not correspond to the original of the claimant. On October 26, 2022, the claimant contacted DIGI informing them of the identity theft. DIGI proceeded to block the line and an internal ticket was opened for a possible case of identity theft, adding to the claimant's ID the following note: "A fraudulent SIM duplicate has been used for this client, we have added the real ID to the ID//Please check ID before validating duplicate."

The second of the fraudulent duplicates was carried out on October 26, 2022, at 16:19 hours, with the presentation of a national identity document that does not correspond to the original of the claimant. The advisor assigned to this validation did not carry out any of the corresponding checks and proceeded to validate the new request.

It should be noted that SIM Swapping is a fraud that allows identity theft by hijacking the phone number through obtaining a duplicate of the SIM card.

In any case, the operator must be able to demonstrate that for this specific case

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/21

has followed the verification protocols implemented when requesting a duplicate of the SIM card.

Well, the result was that DIGI issued the SIM card to a third party who was not the holder of the line.

In light of the above, DIGI fails to prove that this procedure was followed.

In fact, according to the identification procedure described by the responding party, the original identification document should have been verified, and had this operation been carried out correctly, the duplicate should have been denied.

In short, DIGI acknowledges both in its response to the request from this Agency dated February 2, 2023, and in its allegations regarding the Initiation Agreement of this procedure dated April 26, 2023, these facts, stating in this regard: "The aforementioned identity theft, in the first allegedly fraudulent SIM duplicate that has been described in the facts of this case, could only have occurred from the preparation and subsequent use, by the impersonator, of an identification document appearing to be original, but allegedly falsified, which was sent to DIGI for the validation of said first duplicate.

In the case of the second allegedly fraudulent duplicate, it was only possible because the usurper took advantage of the negligence of the DIGI advisor who validated said duplicate, who should have complied, and did not comply, with their obligations, and should have followed, and did not follow, the procedure that DIGI has implemented for the validation of duplicates."

Consequently, as DIGI acknowledges: "the advisor assigned to the task did not follow the procedure that DIGI has established internally (and regarding which all its BackOffice advisors are informed and trained) for the validation of SIM duplicates in accordance with the currently applicable procedure at DIGI.

It is worth mentioning that this procedure, as it cannot be otherwise, involves, among other things, the obligation of the DIGI advisor to (1) review all documentation associated with the ID of the line for which a duplicate is being requested, including the tickets and observations that appear in said ID; (2) check if there are previous duplicate requests, which may constitute an indication that the holder may be a victim of some type of fraud by impersonation; and (3) contact the customer to confirm the password that they would have set as a security measure to prevent unauthorized duplicates.

Unfortunately, in this case, due to negligence, the advisor assigned to this validation did not carry out any of these checks, failing to fulfill their work obligations, and proceeded to validate the new duplicate request, which was activated at 16:30 on October 26, 2022, sending the corresponding informative SMS."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/21

As for the presentation of the ID card by the applicant for the duplicate SIM card at DIGI's points of sale, a copy of which has been provided by the operator, it appears legitimate but is clearly false when compared to the original, which is recorded in DIGI's systems. The false ID includes a completely different person, a different place of birth, different parents, a different date of birth, etc., making it impossible to confuse them.

In any case, the responding party has not been able to prove that the procedure implemented by itself was followed in this case, since, had it been done, the duplicate of the SIM card should have been denied.

In accordance with the evidence available, it is estimated that the conduct of the responding party violates Article 6.1 of the GDPR and may constitute the infringement typified in Article 83.5.a) of the aforementioned Regulation 2016/679.

In this sense, Recital 40 of the GDPR states:

"(40) For processing to be lawful, personal data must be processed with the consent of the data subject or on some other legitimate basis established in accordance with law, whether in this Regulation or under another Union or Member State law to which this Regulation relates, including the necessity of complying with a legal obligation applicable to the data controller or the necessity of performing a contract to which the data subject is party or for the purpose of taking steps at the request of the data subject prior to entering into a contract."

III

Typification and qualification of the infringement

The infringement is typified in Article 83.5 of the GDPR, which considers as such:

"5. Infringements of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 4% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) The basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9."

The LOPDGD, for the purposes of the prescription of the infringement, qualifies in its Article 72.1 as a very serious infringement, with a prescription period of three years in this case, "b) The processing of personal data without any of the conditions for lawful processing established in Article 6 of Regulation (EU) 2016/679."

IV

Sanction of fine. Determination of the amount.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/21

The determination of the sanction to be imposed in the present case requires observing the provisions of Articles 83.1 and 2 of the GDPR, which respectively state the following:

"1. Each supervisory authority shall ensure that the imposition of administrative fines in accordance with this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive."

"2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage suffered;

b) the intentionality or negligence in the infringement;

c) any measures taken by the controller or processor to mitigate the damage suffered by the data

subjects;

- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
 - e) any previous infringements committed by the controller or processor;
 - f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
 - g) the categories of personal data affected by the infringement;
 - h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
 - i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;
 - j) adherence to codes of conduct pursuant to Article 40 or to certification mechanisms approved under Article 42, and
 - k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”
- Within this section, the LOPDGDD provides in its Article 76, titled “Sanctions and corrective measures”:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The link of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.

3. It shall be possible, complementarily or alternatively, to adopt, when appropriate, the remaining corrective measures referred to in Article 83.2 of Regulation (EU) 2016/679.”

Digi requests that the following mitigating circumstances be considered:

- (I) “the absence of prior infringements” (art. 83.2 e) GDPR).
- (II) “At no time have special categories of data been processed” (art. 83.2 g).
- (III) “the cooperation with the supervisory authority by responding to the transfer of the complaint and providing the requested information,” Article 83.2 f) of the GDPR.
- (IV) “The absence of benefits obtained through the infringement,” Article 83.2 k) of the GDPR and 76.2 c) of the LOPDGDD.

None of the invoked circumstances are accepted.

Regarding (I) and (II), it should be noted that such circumstances can only operate as aggravating factors and in no case as mitigating circumstances.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/21

The ruling made by the National Court in its SAN of May 5, 2021 (Rec. 1437/2020) regarding section e) of Article 83.2 of the GDPR, concerning the commission of prior infringements:

“On the other hand, it considers that the absence of a prior infringement should be regarded as a

mitigating factor. Well, Article 83.2 of the GDPR establishes that, among other circumstances, the following must be taken into account for the imposition of the administrative fine: 'e) any prior infringement committed by the controller or the processor.' This is an aggravating circumstance; the absence of the conditions for its application means that it cannot be taken into consideration, but it does not imply or allow, as the claimant intends, its application as a mitigating factor."

(III) Article 83.2.f) of the GDPR refers to the "degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement." The response of the respondent to the information request from the Inspection Subdirectorate did not fulfill these purposes, so it cannot be framed within that mitigating circumstance.

(IV) Regarding the application of Article 76.2.c) of the LOPDGDD, in connection with Article 83.2.k), the non-existence of benefits obtained, it should be noted that such a circumstance can only operate as an aggravating factor and in no case as a mitigating circumstance.

Article 83.2.k) of the GDPR refers to "any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement." And Article 76.2.c) of the LOPDGDD states that "2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account: [...] c) The benefits obtained as a result of the commission of the infringement." Both provisions mention as a factor that can be taken into account in the assessment of the sanction the "benefits" obtained, but not the "absence" of these, which is what DIGI claims.

Furthermore, according to Article 83.1 of the GDPR, the imposition of fines is governed by the following principles: they must be individualized for each particular case, be effective, proportionate, and dissuasive. The admission that the absence of benefits operates as a mitigating factor is contrary to the spirit of Article 83.1 of the GDPR and to the principles governing the determination of the amount of the fine. If, as a result of the commission of a GDPR infringement, it is classified as a mitigating factor that no benefits have existed, the dissuasive purpose fulfilled through the sanction is partially nullified. Accepting DIGI's thesis in a case like the one at hand would mean introducing an artificial reduction in the sanction that truly should be imposed; the one resulting from considering the circumstances of Article 83.2 GDPR that must indeed be assessed.

The Administrative Litigation Chamber of the National Court has warned that the fact that in a specific case not all elements that constitute a modifying circumstance of liability, which by its nature has an aggravating character, are present, cannot lead to the conclusion that such circumstance is applicable as a mitigating factor. The ruling made by the National Court in its

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/21

SAN of May 5, 2021 (Rec. 1437/2020) - although this resolution concerns the circumstance of paragraph e) of article 83.2 of the GDPR, the commission of previous infringements - it is extrapolable to the issue raised, the claim of the respondent that the "absence" of benefits be accepted as a mitigating factor, given that both the GDPR and the LOPDGDD refer only to "the benefits obtained":

"On the other hand, it is considered that the non-commission of a previous infringement should be appreciated as a mitigating factor. Well, article 83.2 of the GDPR establishes that, among other things, the circumstance "e) any previous infringement committed by the data controller or the processor" must be taken into account for the imposition of the administrative fine. This is an aggravating circumstance; the fact that the prerequisite for its application does not occur means that it cannot be taken into consideration, but it does not imply or allow, as the claimant intends, its application as a mitigating factor."

In accordance with the transcribed provisions, for the purpose of determining the amount of the fine to be imposed on the respondent entity as responsible for an infringement classified in article 83.5.a) of the GDPR and 72.1 b) of the LOPDGDD, the following factors are deemed concurrent in the present case:

As aggravating factors:

- The evident link between the business activity of the respondent and the processing of personal data of clients or third parties (article 83.2.k of the GDPR in relation to article 76.2.b of the LOPDGDD). The Judgment of the National Court of 17/10/2007 (rec. 63/2006), in which, regarding entities whose activity involves continuous processing of client data, indicates that "...the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

As mitigating factors:

The respondent party proceeded to effectively resolve the incident subject to the claim (art. 83.2 c).

The balance of the circumstances contemplated in article 83.2 of the GDPR, regarding the infringement committed by violating what is established in its article 6.1 of the GDPR, allows for the imposition of a sanction of 70,000 euros (seventy thousand euros).

Therefore, in accordance with the applicable legislation and evaluated the criteria for the graduation of the sanctions whose existence has been proven, the Director of the Spanish Agency for Data Protection RESOLVES:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/21

FIRST: TO IMPOSE on DIGI SPAIN TELECOM, S.L., with NIF B84919760, a fine of 70,000 euros (seventy thousand euros) for a violation of Article 6.1 of the GDPR, as classified in Article 83.5 of the GDPR.

SECOND: TO NOTIFY this resolution to DIGI SPAIN TELECOM, S.L.

THIRD: To warn the sanctioned party that they must pay the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No. IBAN:

ES00-0000-0000-0000-0000-0000, opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A.

Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once it is enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second month following or the next business day thereafter.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Administrative Contentious Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Administrative Contentious Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm

resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency is not aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, the provisional suspension would be considered terminated.

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/21